STHIROS
Strategy. Risk. Cyber. AI.

# Closing SoD conflicts across five core systems for a major NBFC's RBI compliance

A major NBFC engaged Sthiros for a comprehensive Information Systems Audit covering RBI Master Directions compliance, IT General Controls, and application security across its core lending stack.




| Client | Service | Sector | Geography |
|---|---|---|---|
| **A Major Non-Banking Financial Company (NBFC)** | **Information Systems Audit & RBI Master Directions Compliance** | **Financial Services, Lending** | **India** |

## The Challenge:

### When core lending systems can't agree on who has access to what

This NBFC needed a comprehensive IS audit across its Loan Origination System, Loan Management System, ERP, and HRMS, spanning regulatory governance, technical application review, and every major control domain from access management to business continuity.

#### Access Management
Conflicting role assignments spanned LOS, LMS, D365, AWS, and GitLab, with inadequate access reviews and delayed user deactivation.

#### Security Controls
Lack of encryption, unauthorised removable media access, and unrestricted external data sharing exposed the environment to compromise.

#### Password & Data Protection
No uniform password configurations existed, with no key rotation and sensitive credentials shared between users.

#### Governance & Compliance
Vendor performance reviews and due diligence were missing, alongside deviation from regulatory DR drill guidelines.

#### Monitoring & Response
Audit trails were incomplete, incident evaluations were lacking, and incident response plans had never been tested.

## The Solution:

### A remediation programme across every control domain, not just the loudest one

Sthiros ran a structured audit against RBI Master Directions, IT General Controls, and application security across LOS, LMS, ERP, and HRMS, surfacing conflicts and gaps system by system.

Every finding was paired with a specific remediation, from RBAC redesign to vendor governance, closing gaps at the control level rather than issuing a generic checklist.

## The Methodology

1

### Role-Based Access Controls & Reviews

RBAC implemented across every core system with regular access reviews, eliminating conflicting role assignments at the source.

2

### Encryption & Removable Media Controls

Encryption standards enforced and removable media restrictions deployed to close the exposure created by unauthorised data movement.

3

### Standardised Password & Key Management

Uniform password configurations and key rotation policies established, ending the sharing of sensitive credentials.

4

### Vendor Governance Strengthening

Vendor performance reviews and due diligence processes strengthened to close third-party oversight gaps.

5

### Audit Trail & Incident Response Completion

Complete audit trails established with timely incident evaluations and tested incident response plans.

6

### Application Control & Vulnerability Resolution

BRDs aligned, input controls strengthened, and vulnerability resolution expedited across every application in scope.

## What This Means

**Access rights need an owner.**

**One password policy, not six.**

**Vendors get reviewed too.**

## Outcomes

### SoD Conflicts

**Eliminated across access controls**

Conflicting role assignments closed across LOS, LMS, D365, AWS, and GitLab.

### Consistent

**Password policies**

Uniform configurations and key rotation replacing shared, static credentials.

### RBI-Aligned

**Compliance and governance**

IT controls brought in line with RBI Master Directions and the Cyber Security Framework.

### Faster

**Vulnerability resolution**

Optimised incident and system management across every application.

## Get in touch

**Is your NBFC's IT control environment tested, or just assumed?**

Speak to Sthiros about what a structured Information Systems Audit can unlock for your RBI compliance posture.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.